Project 01: Conducting Vulnerability Assessment and Penetration Testing on a Simulated Web Application Environment

Solution:

Some Pre-requisite is required before this project:

Task 01: VMware Workstation and Windows Server 2022 Installation

(I) Download VMware Workstation:

Download and install VMware Workstation Pro from the official VMware/Broadcom website.

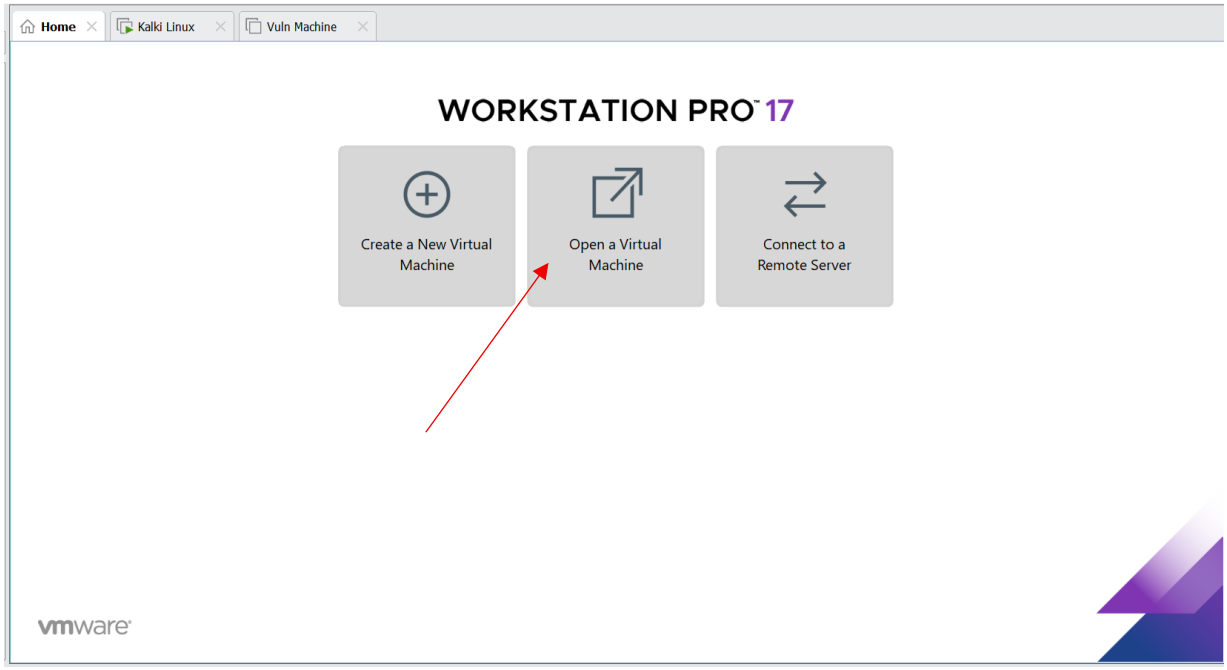
(ii) Download the Kali Linux machine and add in VMware:

(iii) Vulnerable machine required (target machine):

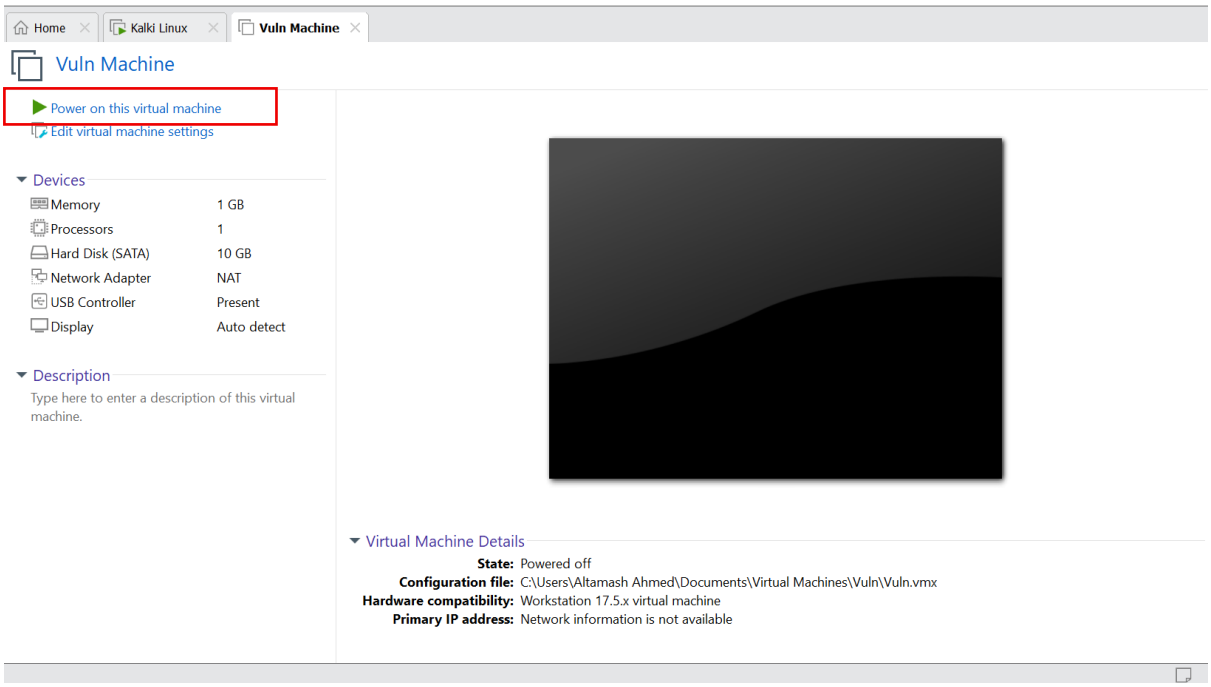
link to download ➞

https://1drv.ms/u/c/87ae59562583bb6d/EZ5_3sJ9Sc9JsPQ7YpDyfB4BIpliAx0skG1edBeSS9qqbA?e=47mc9T

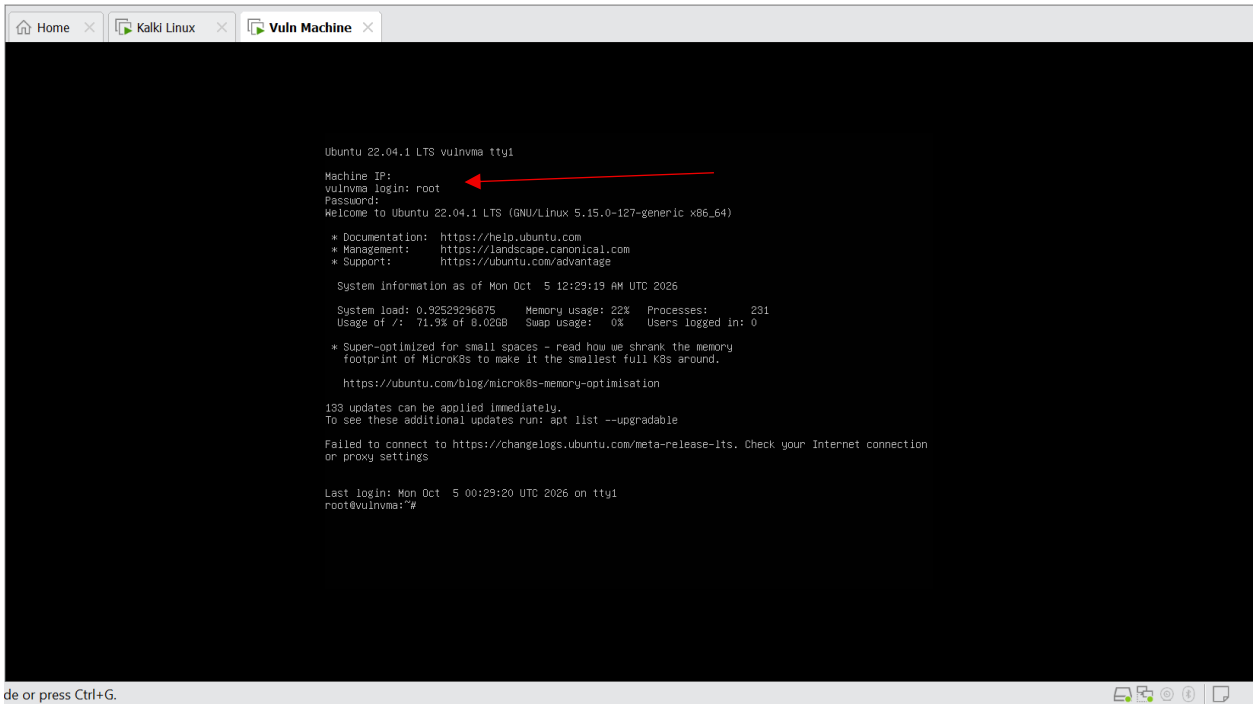
After downloading the target machine open your VMware and click on “Open a Virtual Machine” and select the downloaded OVF file.



Then Power on the target machine called “vuln machine”



After that login the vuln machine username “root” and password “toor” and assign the IP address to machine.



Task 02: Assigning IP in CTF machine, Linux commands are below

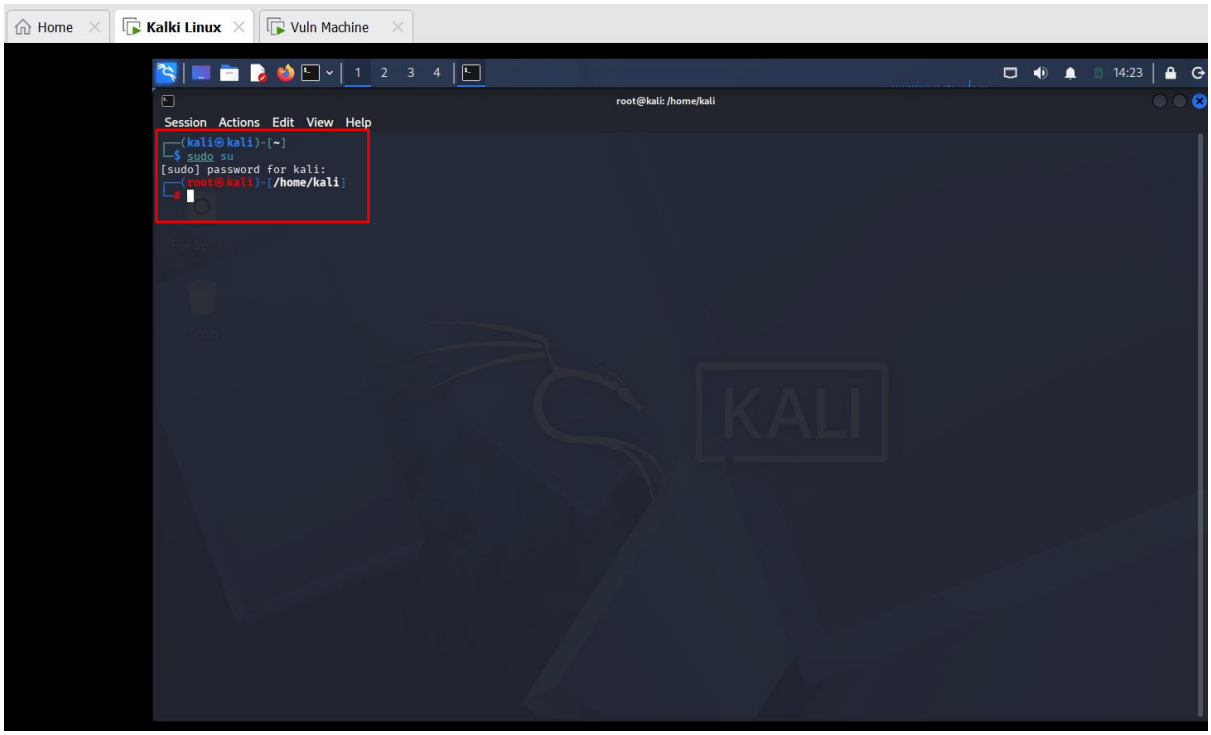
check interface: ip-br addr.

If its show DOWN then UP the interface “sudo ip link set ens33 up”

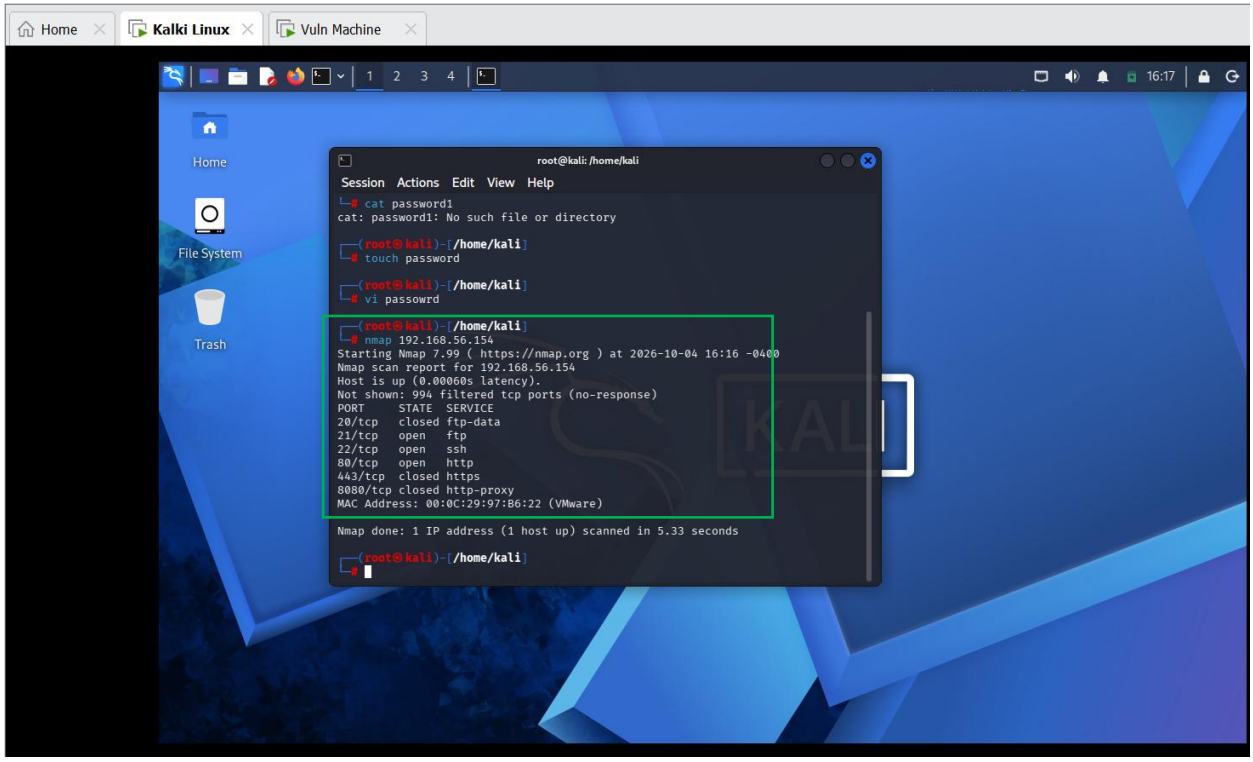
then assign the DHCP IP to machine “sudo dhclient -v ens3

We done the basic configuration. Now you can ping the target machine through Kali Linux if the machine getting response means we are connected within the same network if not check the VM.

Now open the Kali Linux Machine with your username and password and login as a “root” command sudo su (Superuser Do Switch User)
In my case username: kali
password: kali
sudo password: kali

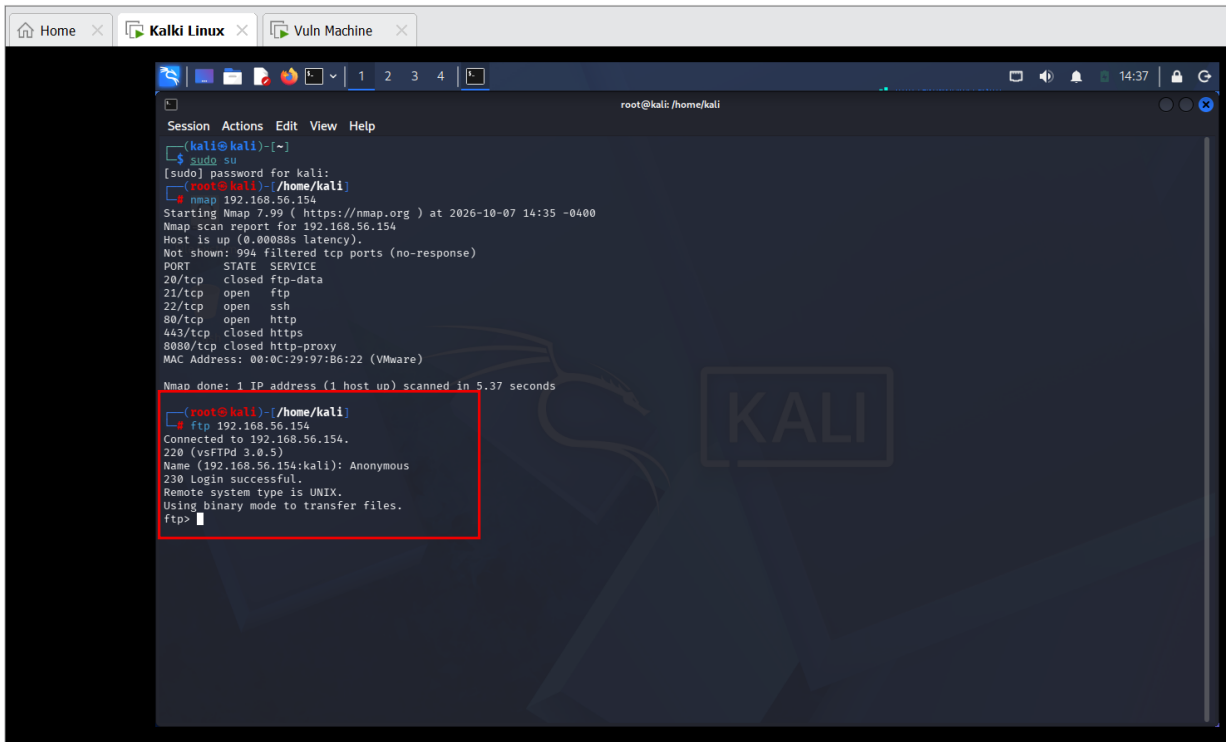


Task 03: Now in your Kali Linux Machine open terminal and run the Nmap 192.168.56.154. This will start performing and scanning the CTF Machine [IP: 192.168.56.154], As we found some ports are open now, we will exploit them.

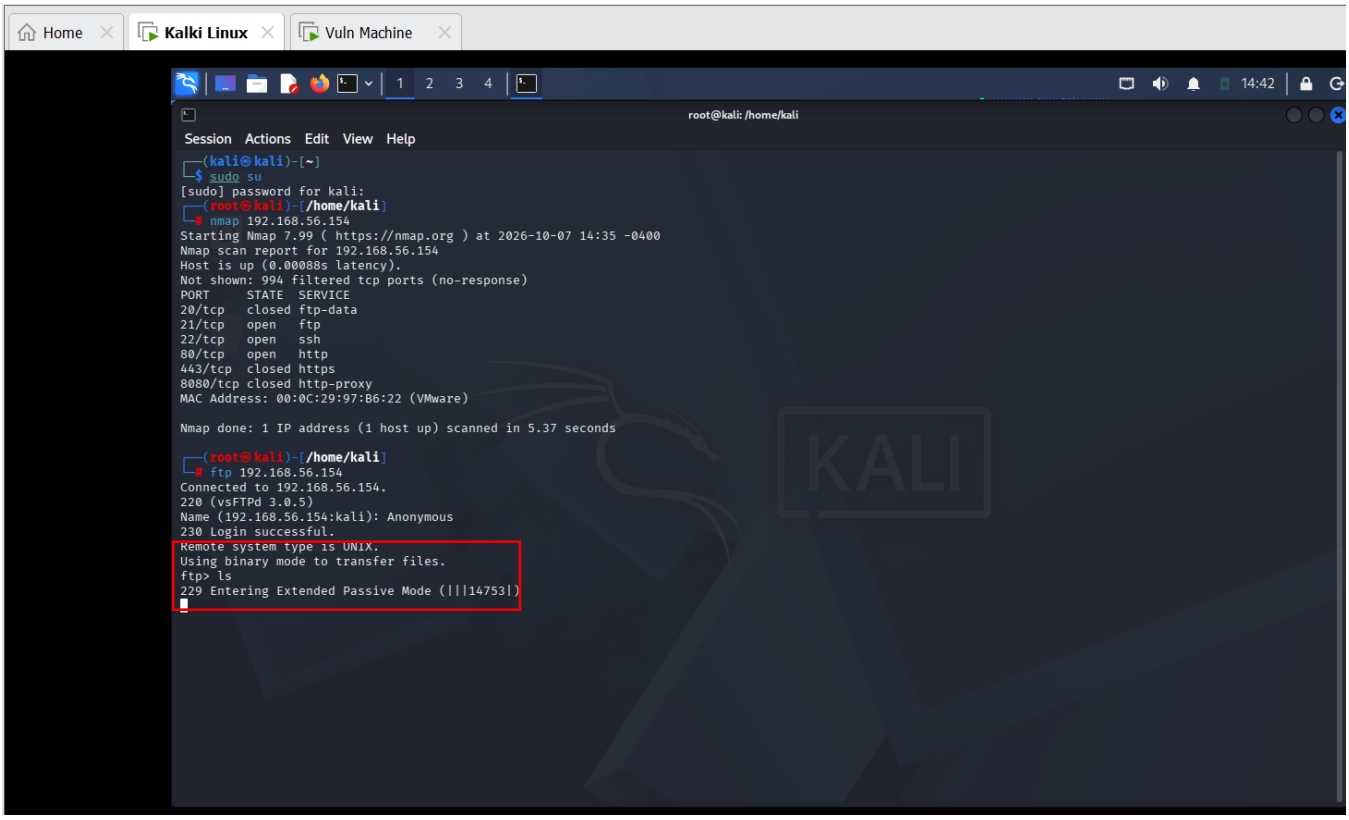


Task 04: Vulnerability Assessment

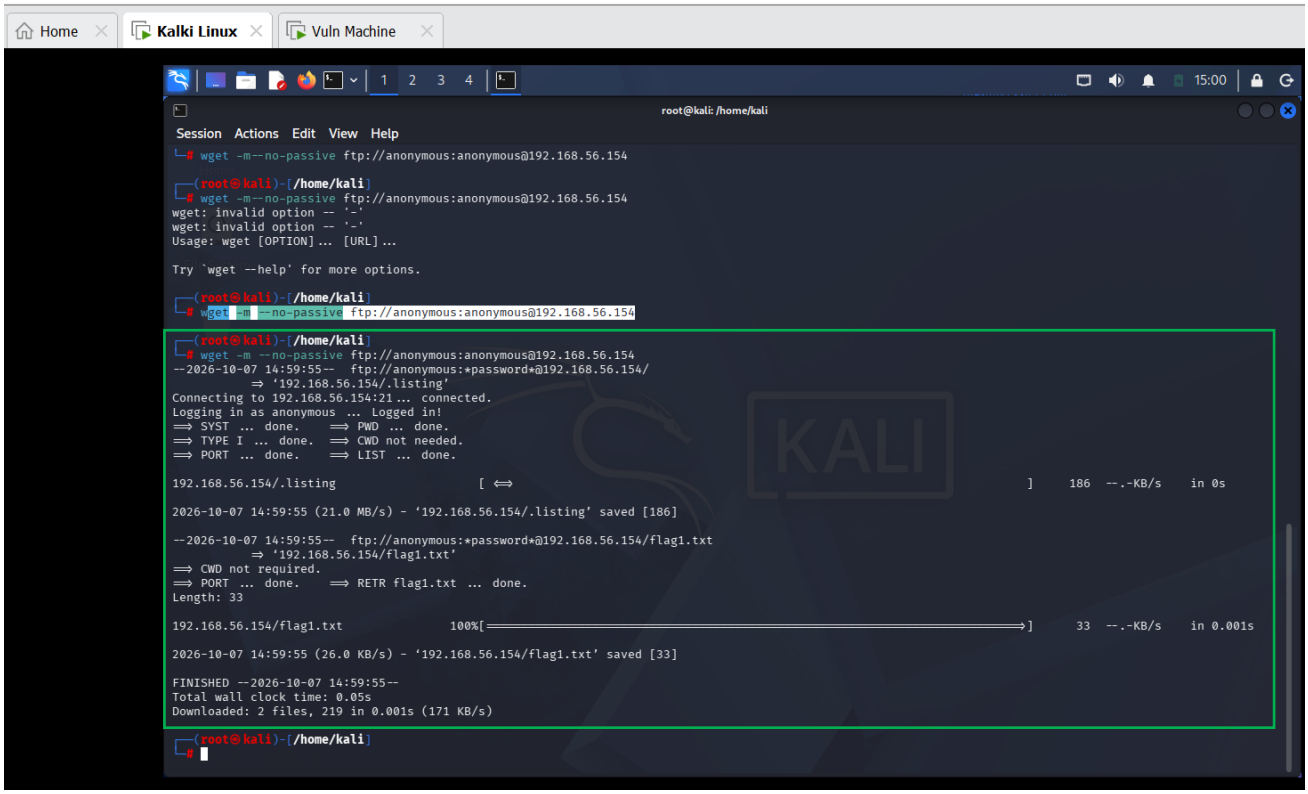
Now use command: “ftp 192.168.56.154” to connect. And use credentials as Anonymous to try logging if allowed.



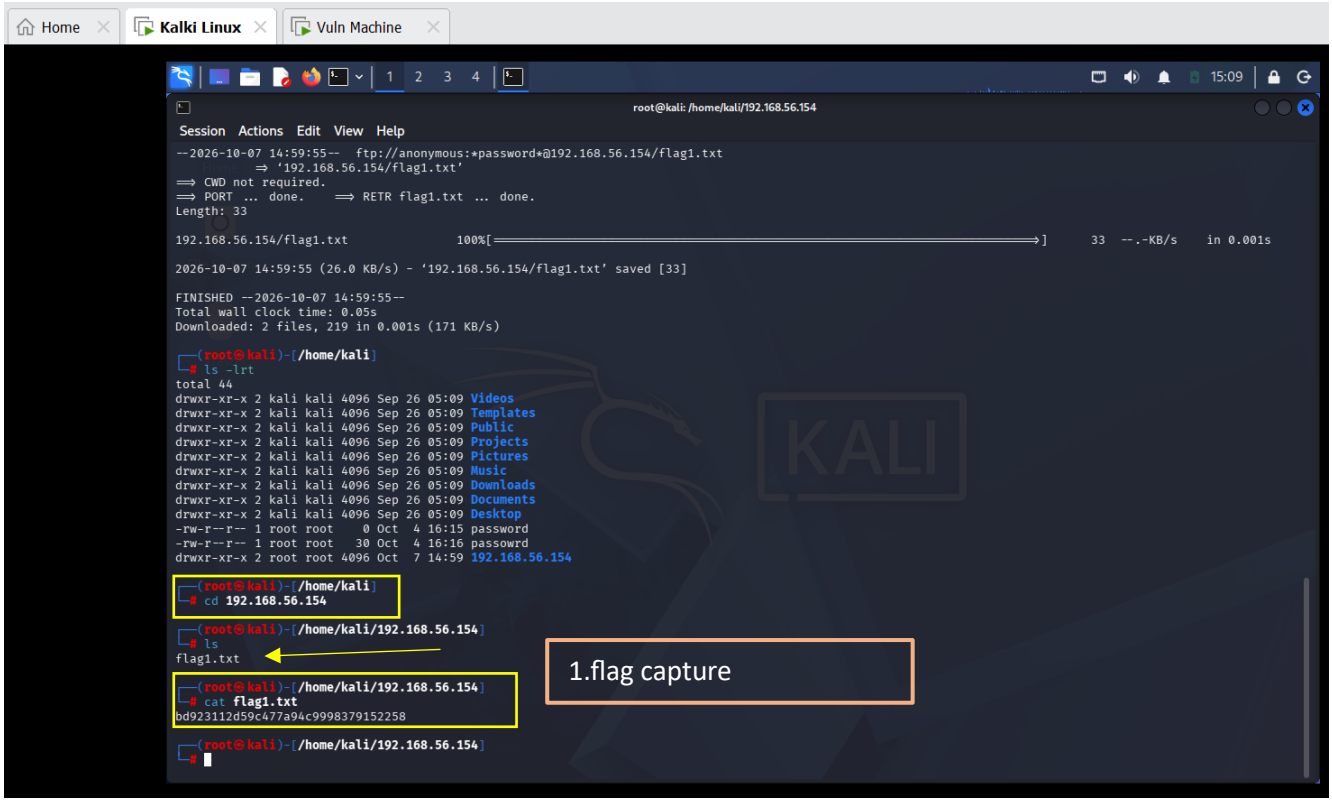
Now use the “ls” command to see the list of files in ftp.



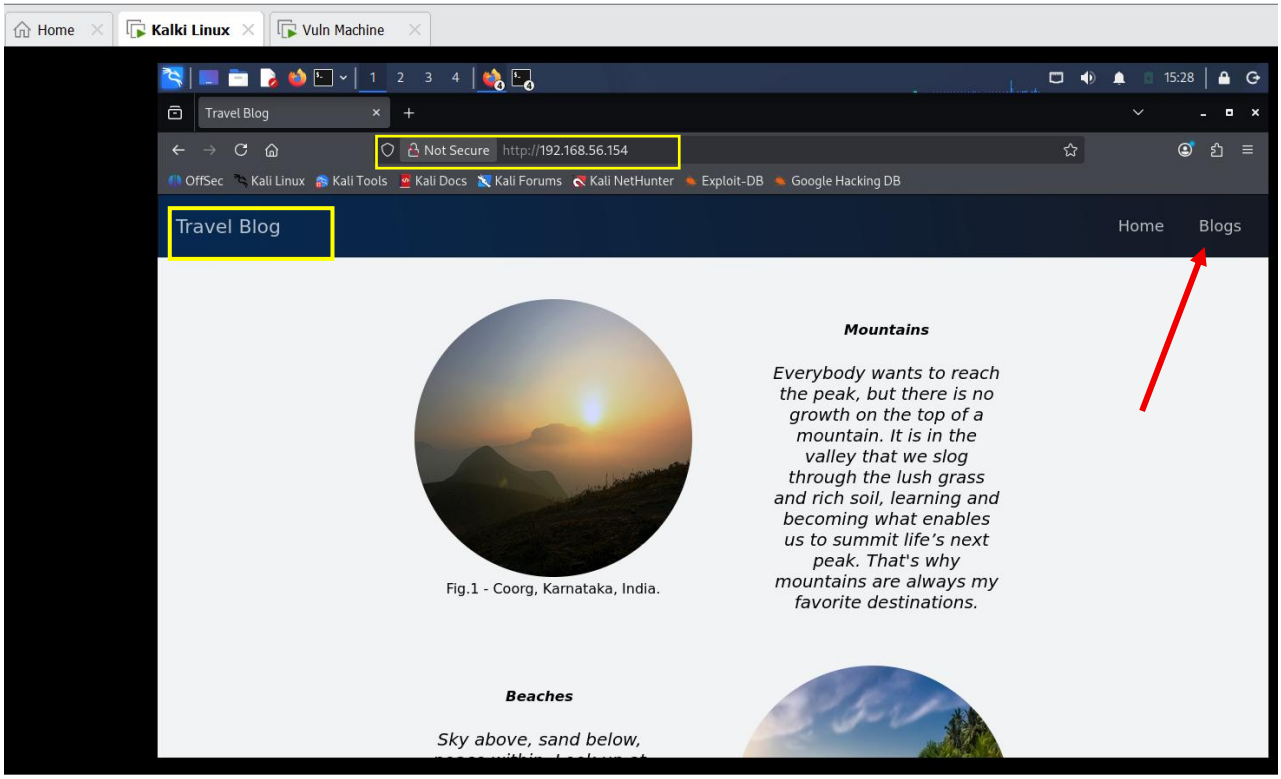
Now type exit to get out from the “ftp”, Now in terminal use the command: “get-m --no-passive ftp://anonymous:anonymous@192.168.56.154” then you will see the file gets downloaded.



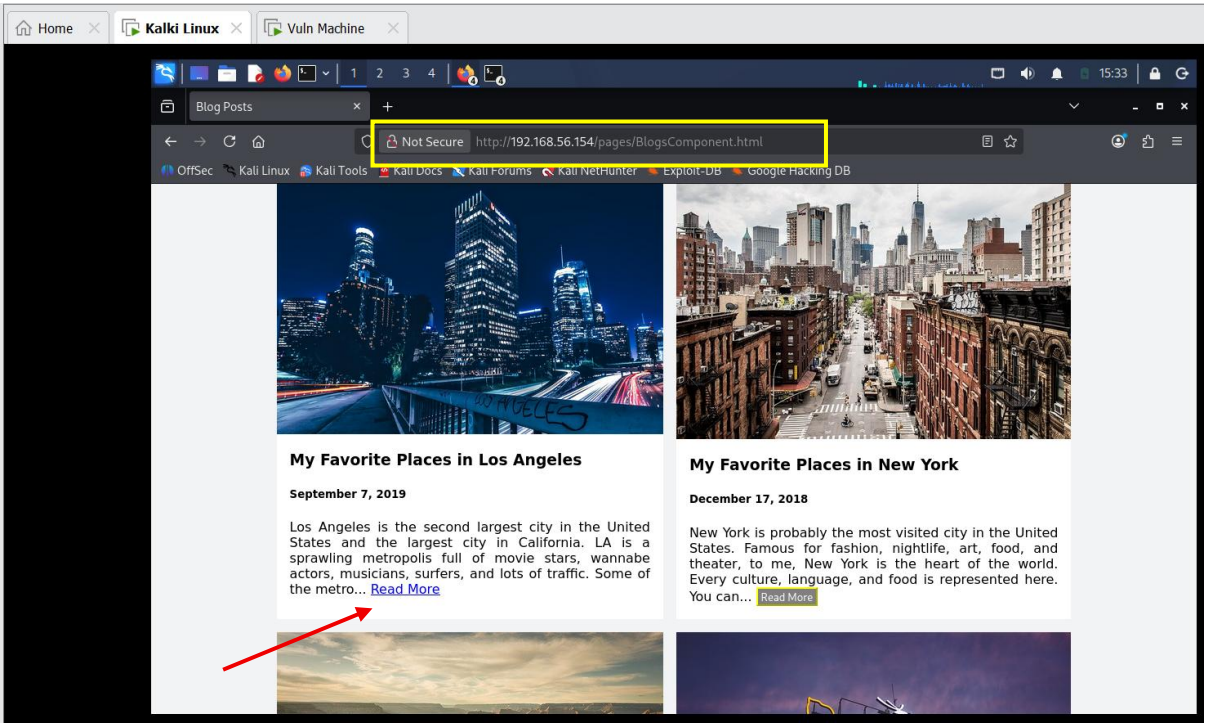
Now type command: ls-lrt to see the all list of directory, then moved into that directory to see “flag1.txt file appears, then user “cat” command to view the content of the file, the value is “bd923112d59c477a94c9998379152258”

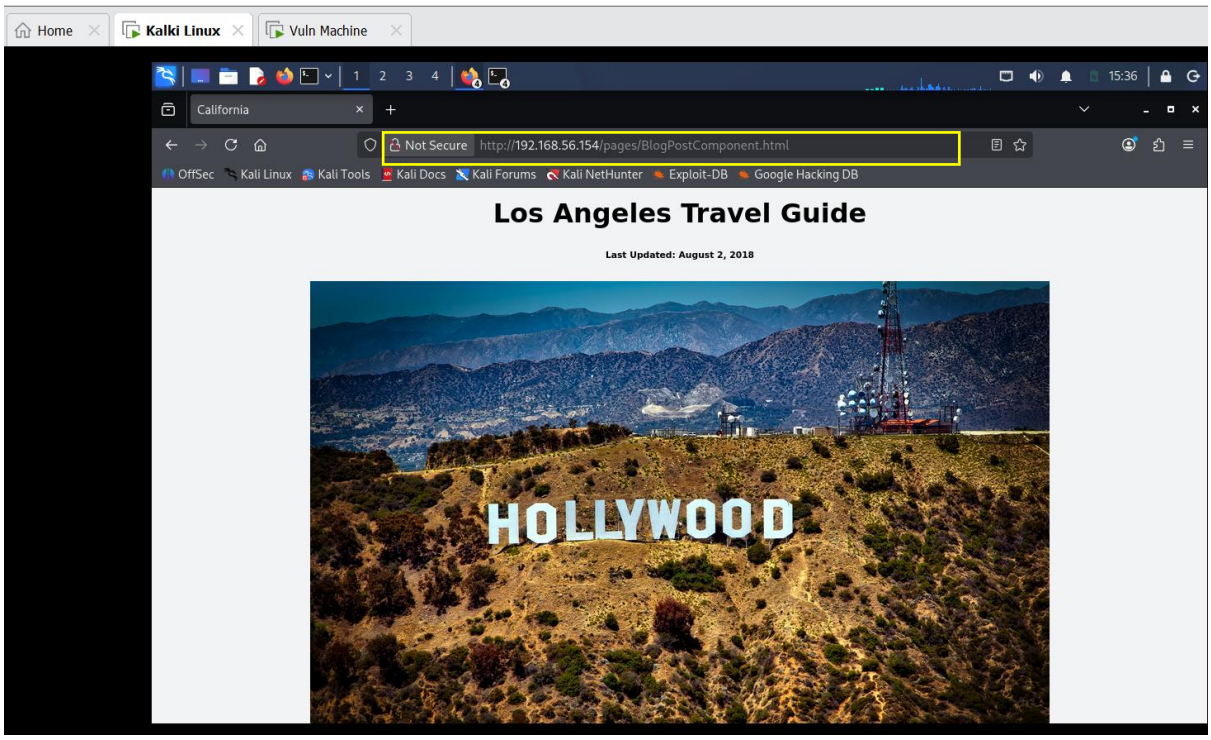


Now as we have http port open now let's see which type of website the site is hosting. Open a Firefox browser and search: “http://192.168.56.154”. Then you will see the website is appeared. It represents a “Travel Blog” then now click on “Blog”

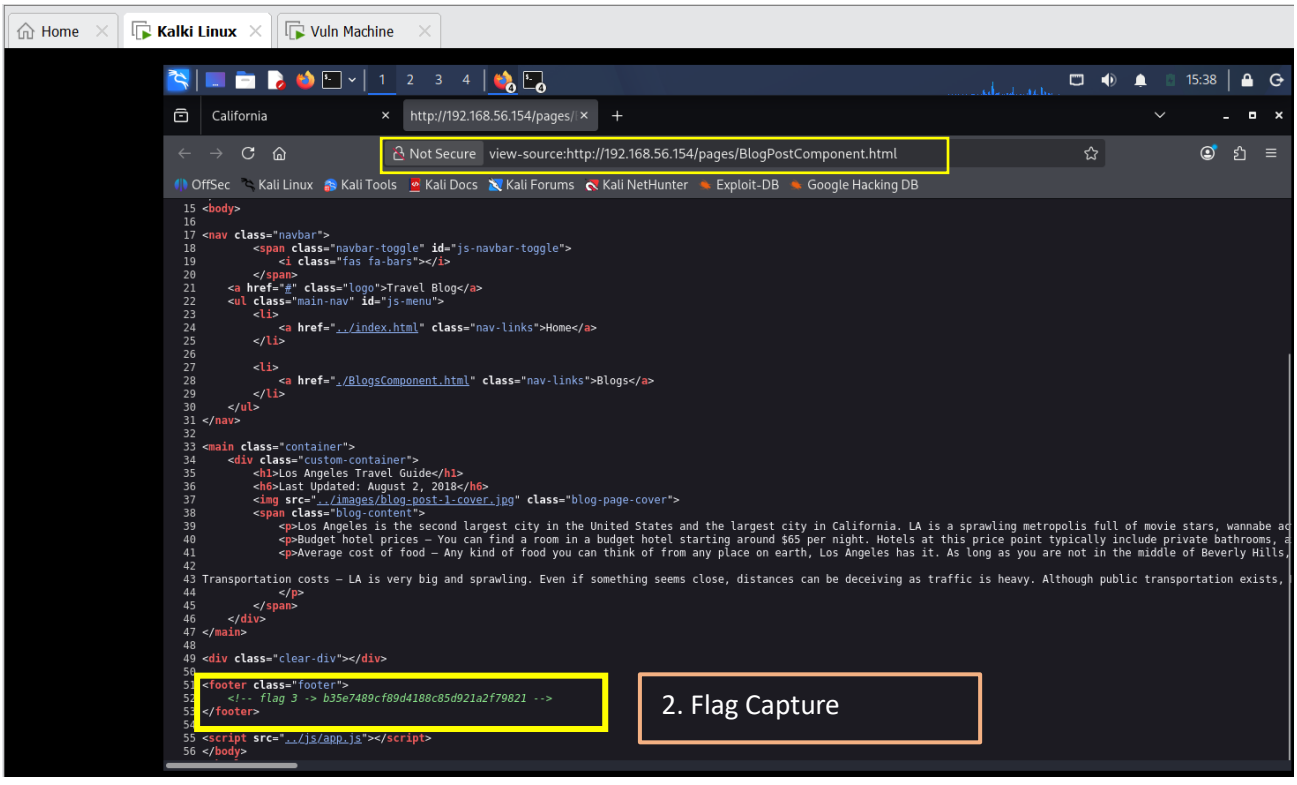


Now Click on “read more”



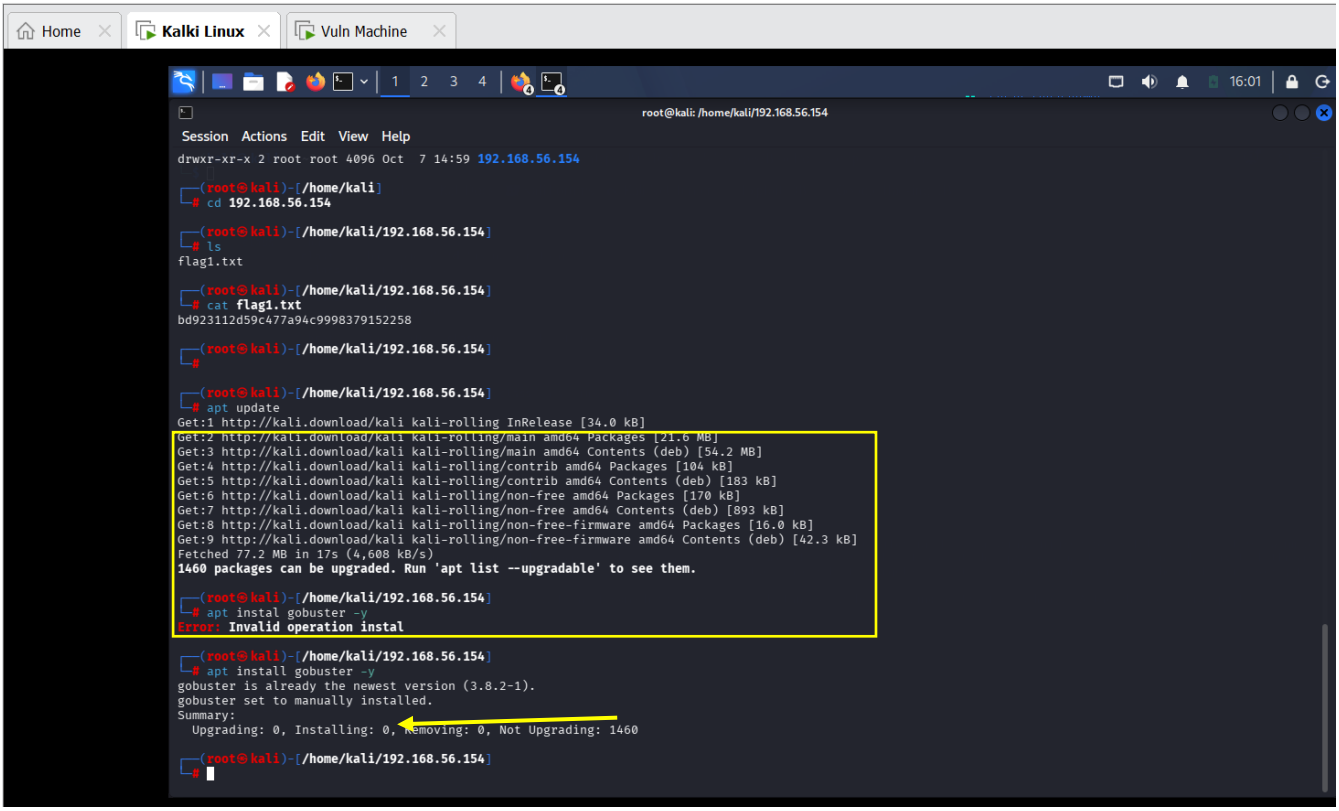


Now press “CTRL+U” you will enter in developer page now you can view the source of the website. Then you will a see a flag present

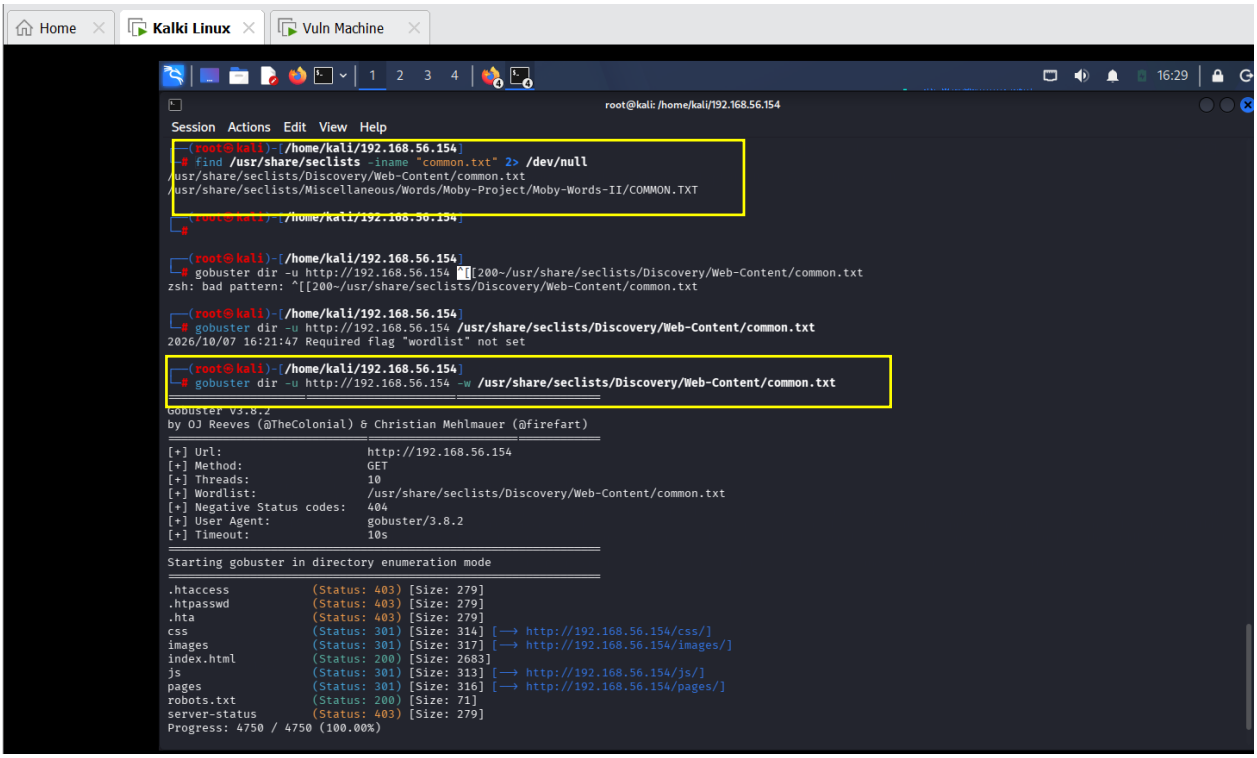


The value of the flag is: “flag 3-> b35e7489cf89d4188c85d921a2f79821”

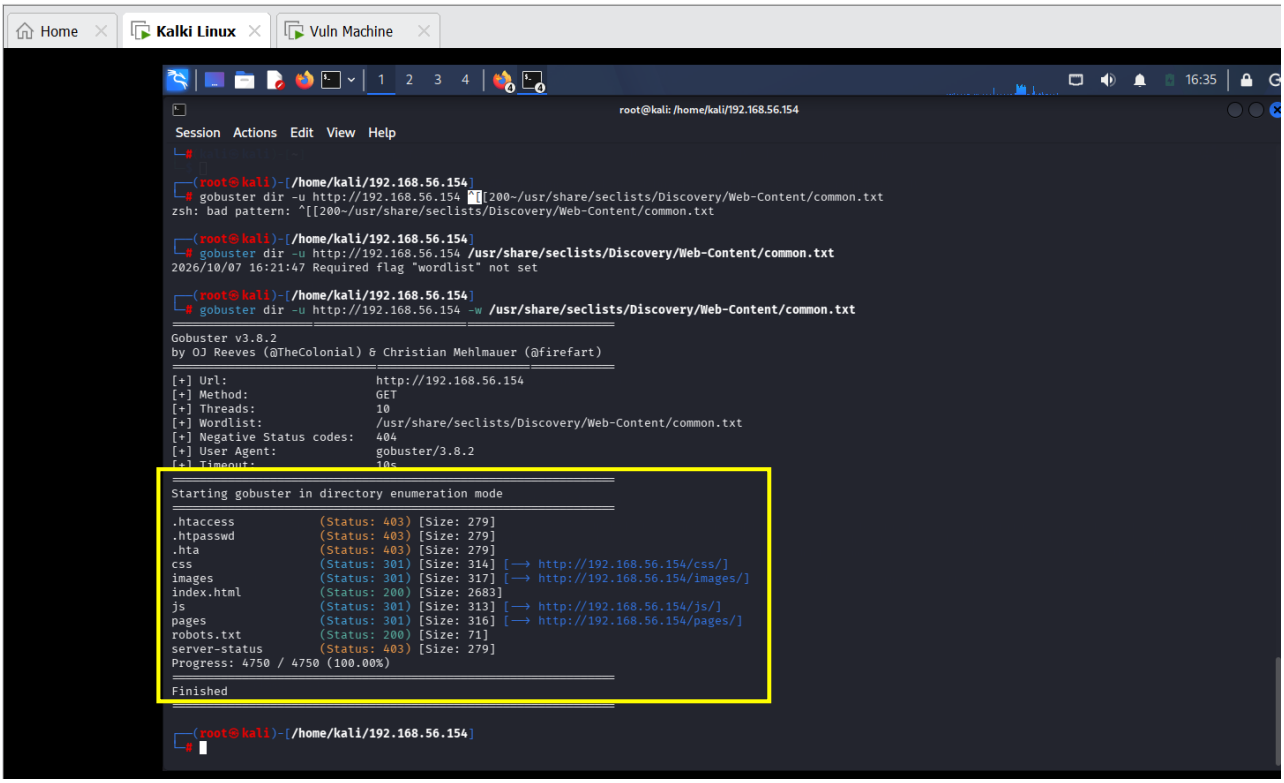
Now we have to perform directory bursting. Before that update the linux command “apt update” and install the gobuster command “apt install gobuster-y”.



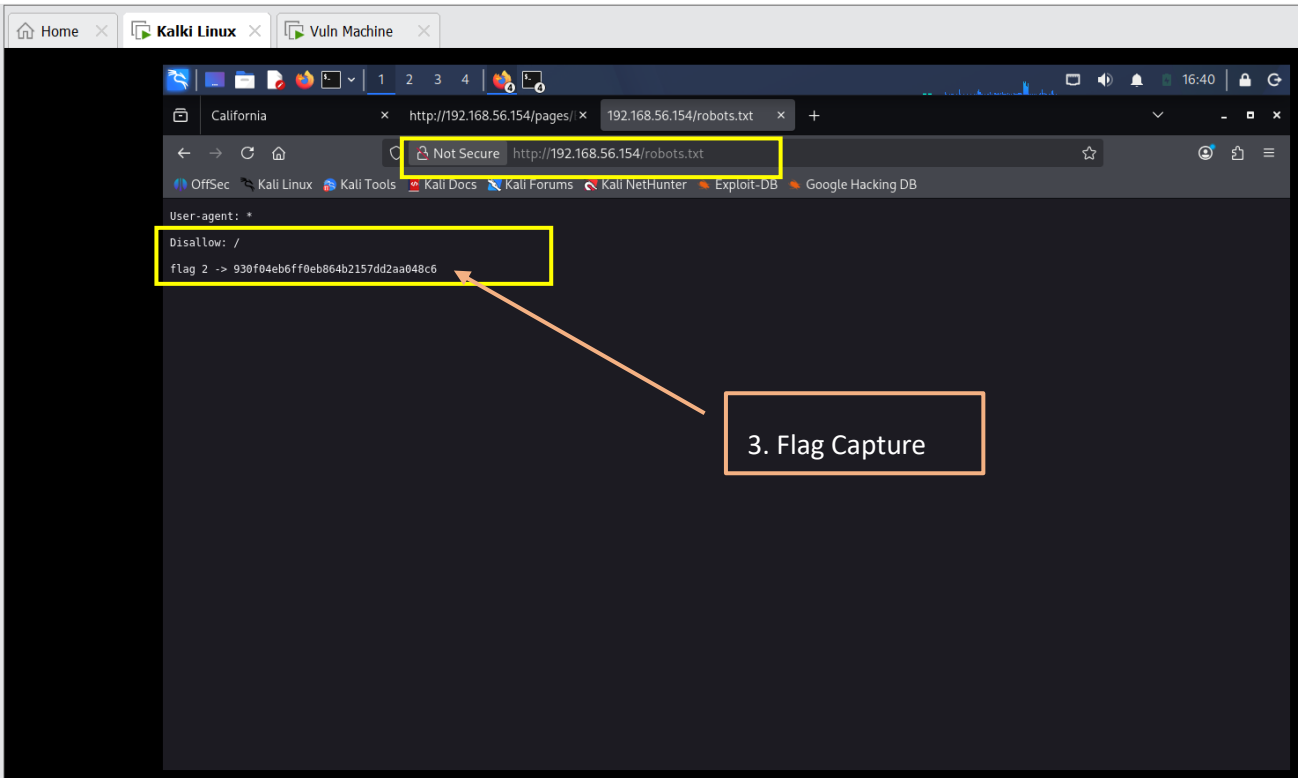
Now install seclists for wordlist file in Linux. Command “apt install seclists -y”. Then run the command “find /usr/share/seclists-iname “common.text” 2> /dev/null, it will appear path like /usr/share/seclists/Discovery/web-Content/Common.txt, Then select the path and run the command “gobuster dir-u http://192.168.56.154-w /usr/share/seclists/Discovery/web-Content/Common.txt



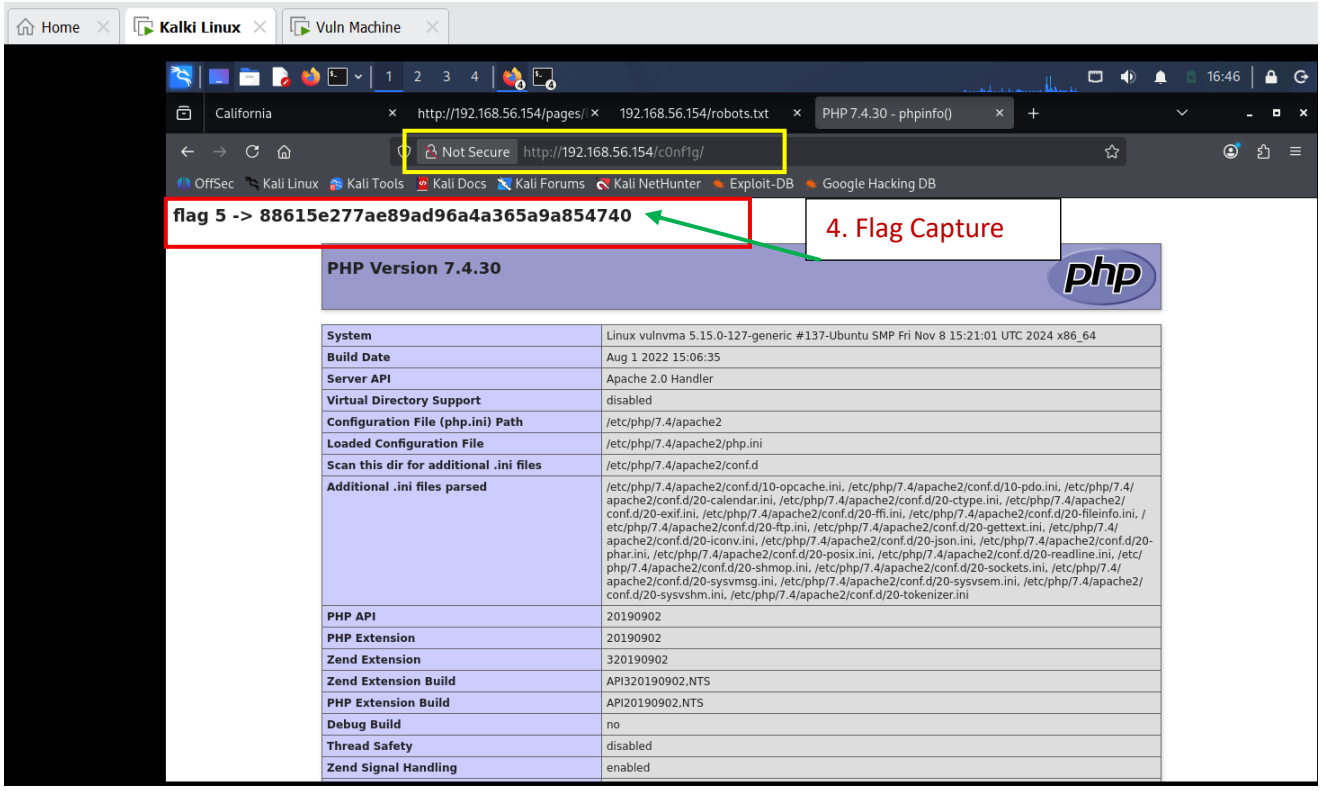
Now you can see we have successfully found some directory



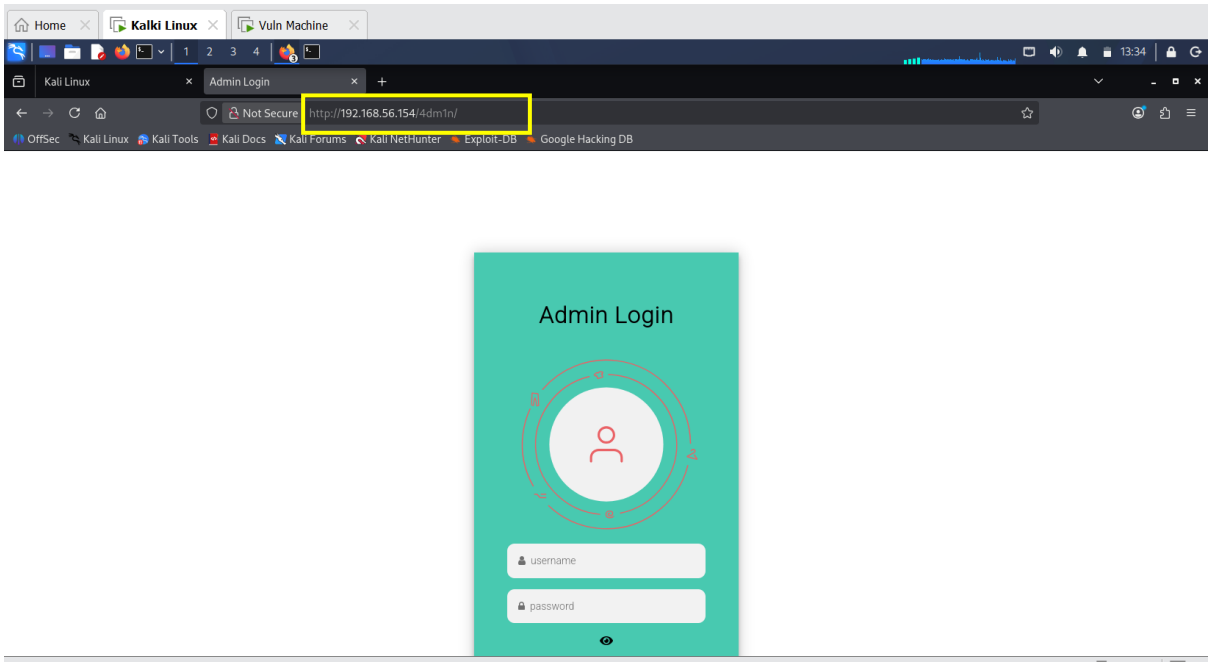
Now navigate to the website: “http://192.168.56.154/robots.txt”. Then you will see a flag will appear. The value “flag 2-> 930f04eb6ff0eb864b2157dd2aa048c6”



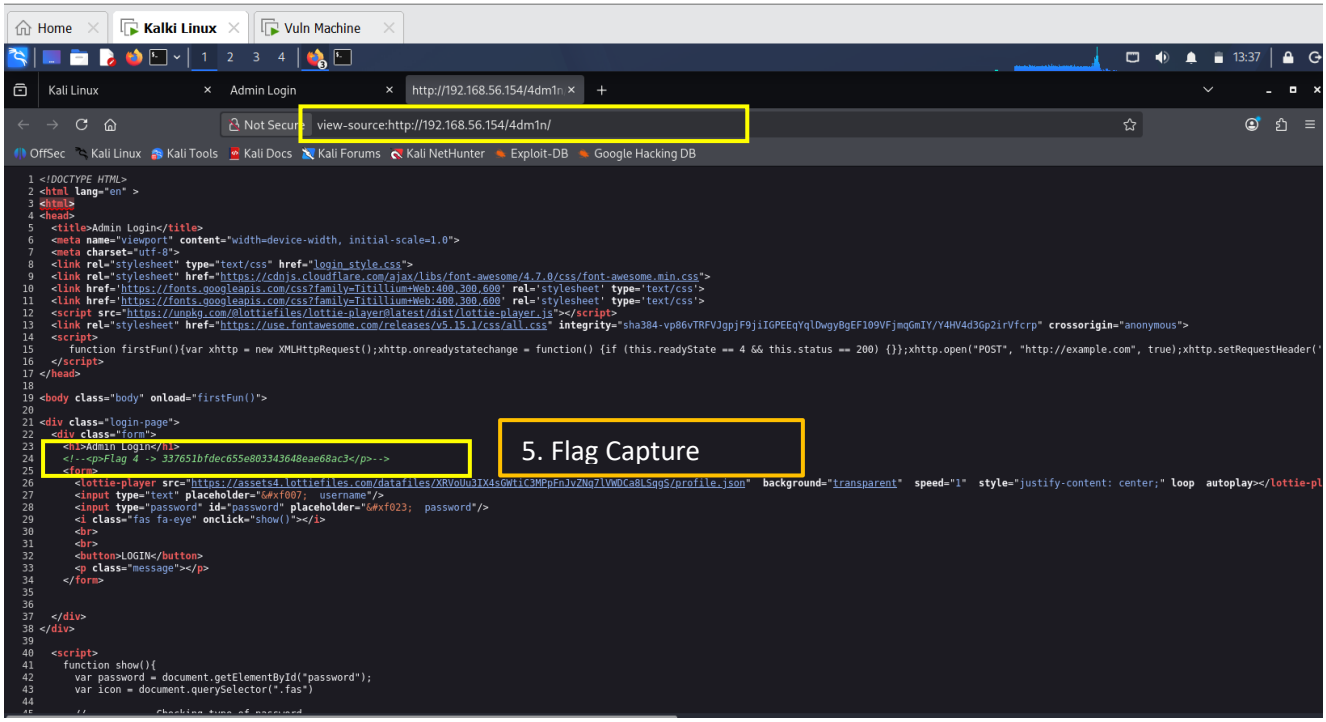
Now browse this http://192.168.56.154/c0nf1g to configuration of the application and flag 5 “88615e277ae89ad96a4a365a9a854740”



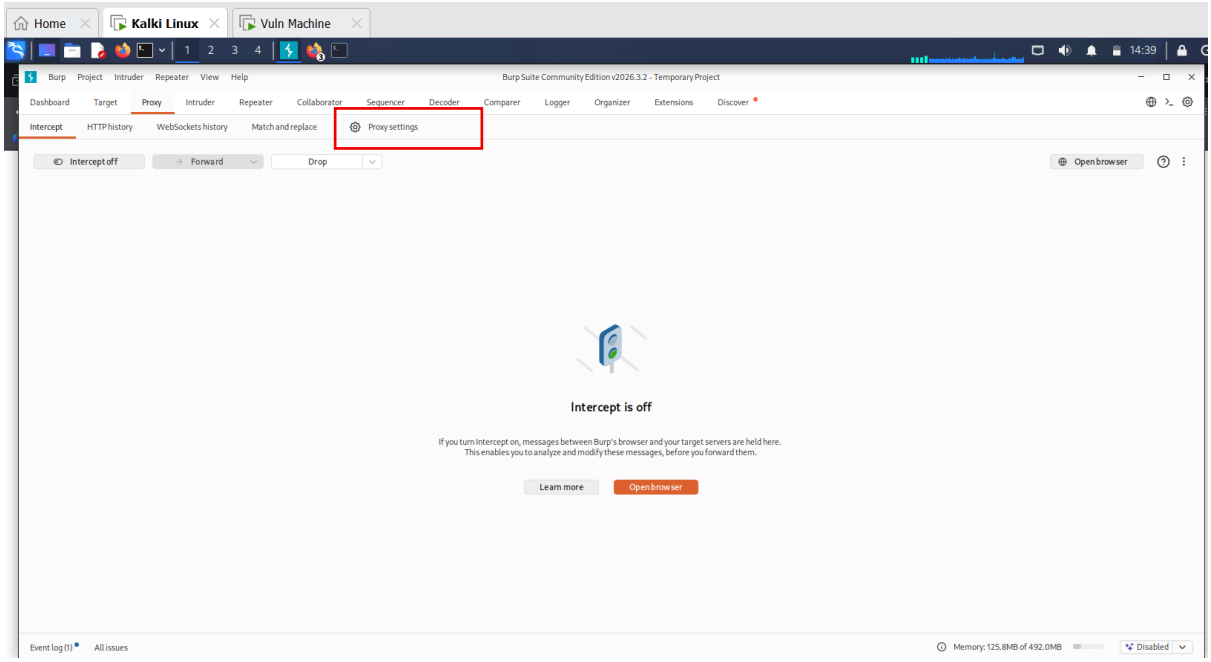
Now navigate to the website: “http://192.168.56.154/4dm1n/”. Then you will see the following log in page appears

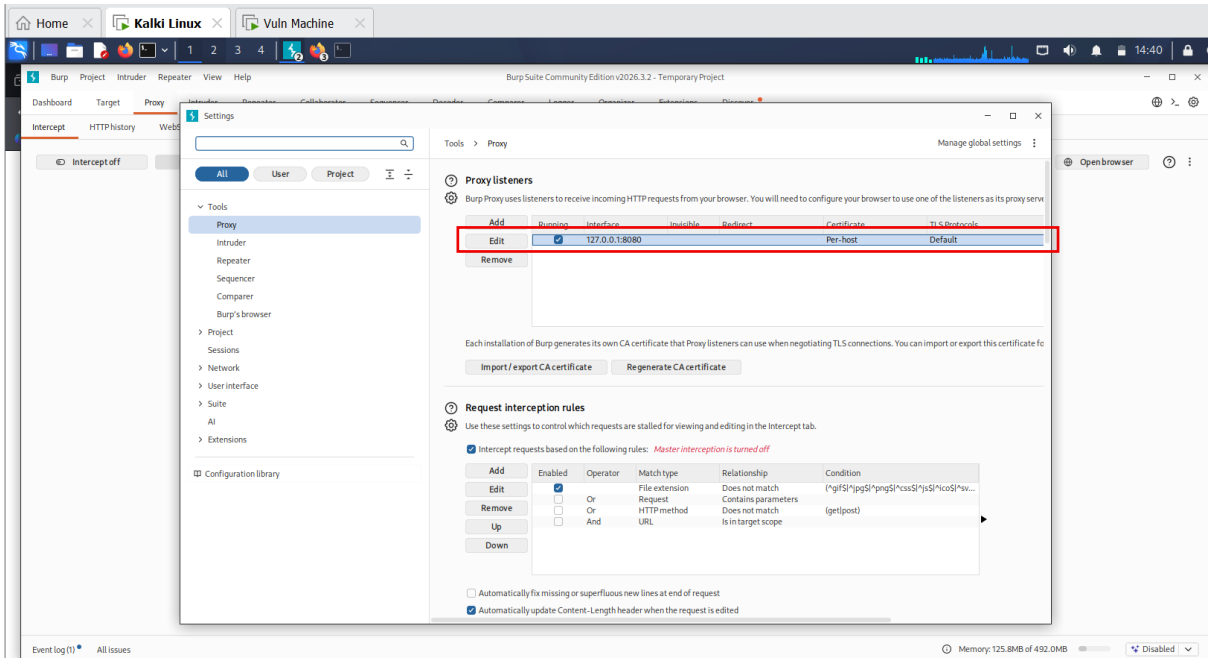


Now press the Ctrl+U to see the source of the website. Then you will see the flag is appear
Flag 4-> 337651bfdec655e803343648eae68ac3

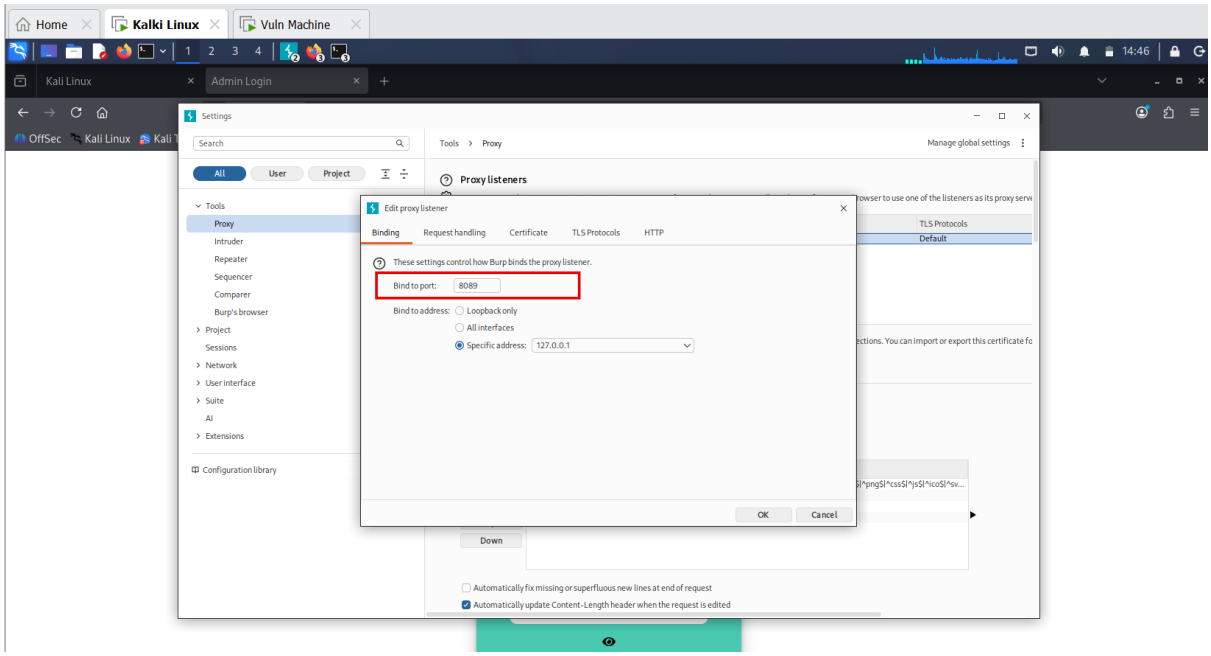


Now Set up the Burp suite, go to the proxy setting set up the port

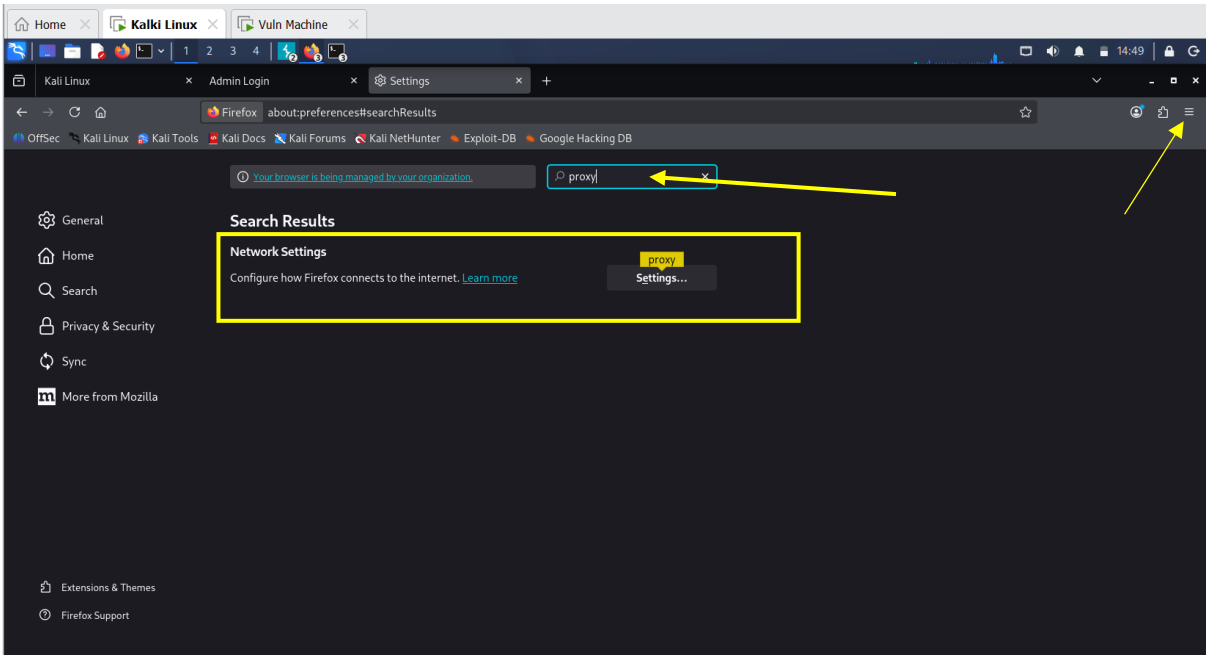




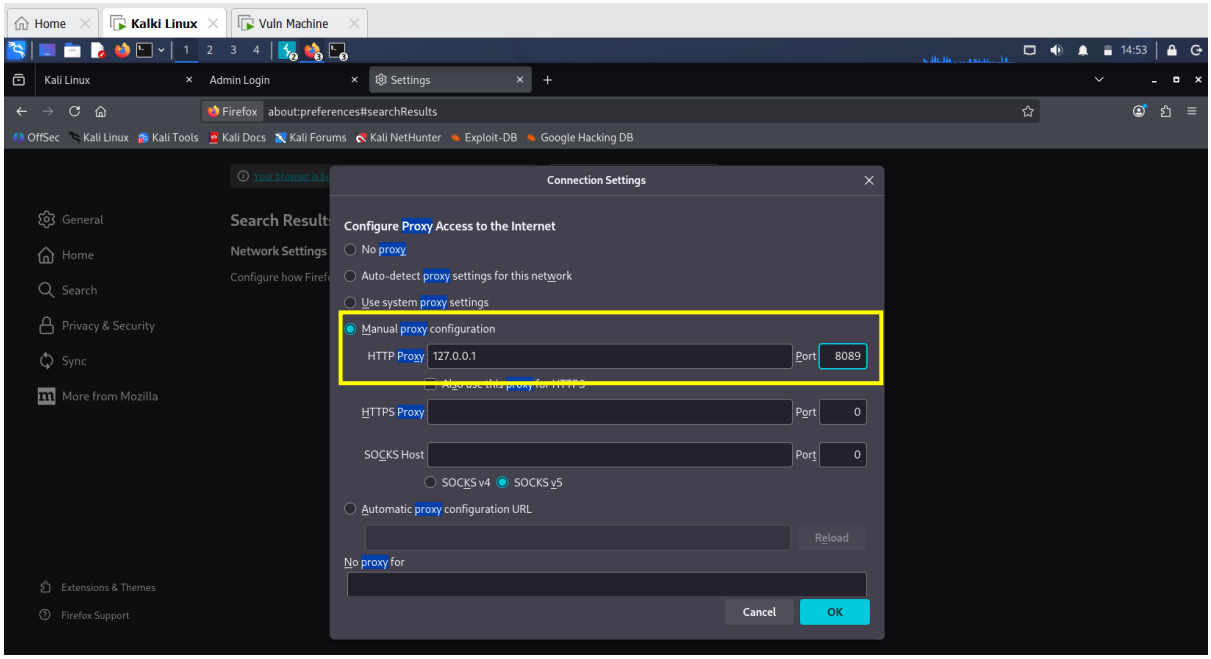
Now Click on the edit option to set the post as 8089.



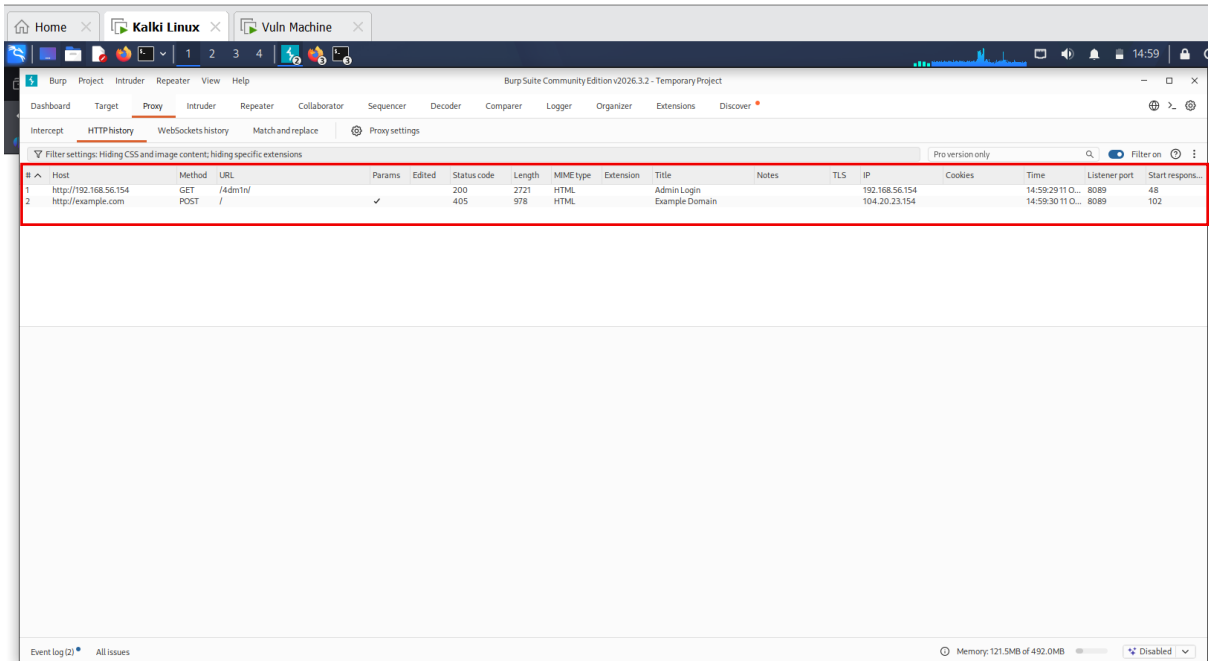
Then go to the Firefox browser setting and search “proxy”.



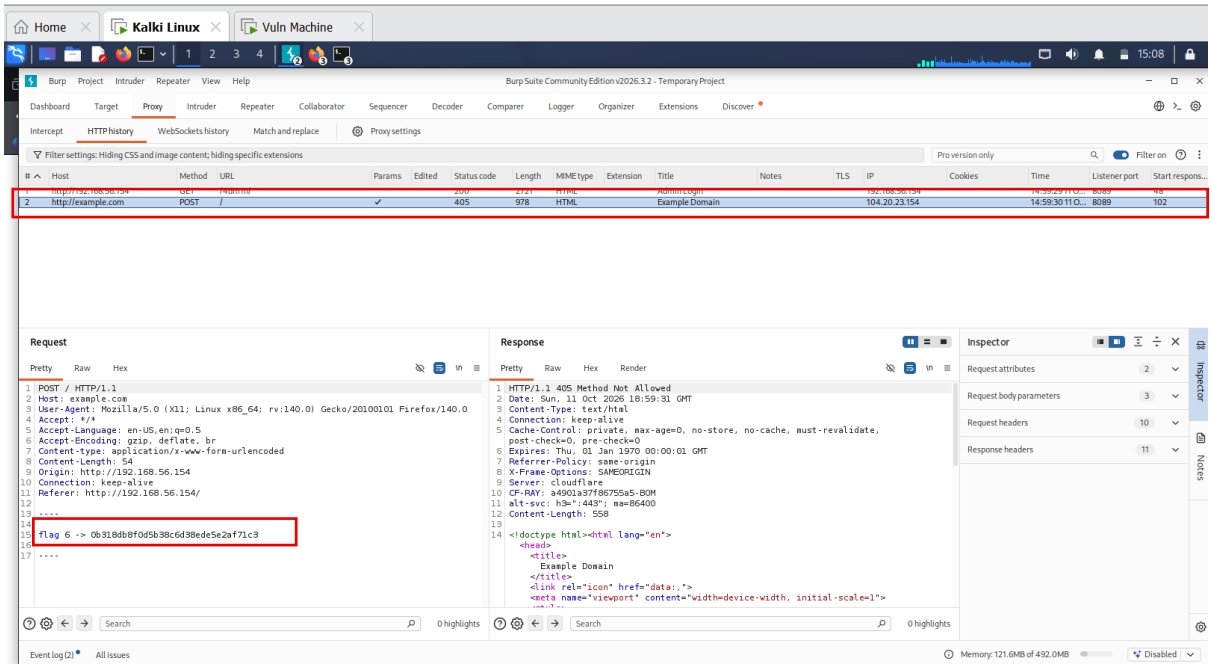
Now setting the connection as per Burp suite HTTP proxy “127.0.0.1 and port “8089”



Now go to the admin page and refresh the page the and see the request coming from the website to the burp suite.



Now we can check that we capture the two host one is “admin page” and other one is “example.com”



And the value is flag 6-> 0b318db8f0d5b38c6d38ede5e2af71c3

Project 01: Simulated Web Application Environment

Target IP: 192.168.56.154 Environment: VMware Workstation, Kali Linux, Vulnerable Target Machine Tools Used: Nmap, FTP, Gobuster, Firefox Developer Tools, Burp Suite

1. Report on Vulnerabilities in the Application

The assessment was conducted to identify security weaknesses in a simulated travel blog web application. Testing focused on network services, FTP access, website source code, hidden directories, configuration endpoints, and the administrative login page.

The assessment identified several potential security concerns, including anonymous FTP access, information exposure in website source code, insecure file access, discoverable directories, and publicly accessible administrative and configuration-related endpoints.

2. Findings and Recommendations

V-01: Anonymous FTP Access

Anonymous FTP access and file retrieval were tested, potentially allowing unauthorized users to access files.

Recommendation: Disable anonymous FTP, restrict file permissions, and use secure file-transfer protocols.

V-02: Sensitive Data Exposure

A flag was found in the website's HTML source code, demonstrating that client-side information can be viewed by visitors.

Recommendation: Never store passwords, API keys, or confidential information in client-side code.

V-03: Insecure File Access

FTP files and hidden web resources were identified during testing, requiring further verification of file permissions.

Recommendation: Restrict access to sensitive files and apply least-privilege permissions.

V-04: Admin Panel Access Control

An administrative login page was discovered at /4dm1n/, but an authentication bypass was not confirmed.

Recommendation: Implement strong authentication, multi-factor authentication, and server-side authorization.

V-05: Web Application Misconfiguration

Gobuster discovered paths such as /robots.txt, /c0nf1g, and /4dm1n/.

Recommendation: Disable directory indexing, remove unnecessary endpoints, and restrict sensitive resources.

V-06: Configuration Endpoint Exposure

The /c0nf1g endpoint was accessed, but disclosure of sensitive configuration information was not confirmed.

Recommendation: Restrict access to configuration resources and ensure confidential settings are not publicly accessible.

3. Security Configuration

Regular Audits and Updates: Conduct regular vulnerability scans and keep software, services, and security configurations updated.

Developer Training: Train developers in secure coding, authentication, authorization, and sensitive data protection.

Access Control: Apply least-privilege permissions and verify authorization on the server.

Monitoring: Monitor logs for suspicious access attempts and unusual activity.

4. Conclusion

The assessment identified potential security weaknesses in the simulated web application, particularly involving FTP access, source-code information exposure, file permissions, hidden directories, and administrative endpoints.

Implementing the recommended controls will help improve application security and reduce the attack surface. Further testing is required to confirm vulnerabilities whose impact has not yet been demonstrated.